

SIMATS ENGINEERING

ASSESSMENT TOOL 2

Name	Abinesh M
Register Number	192465050
Date	
Time	1 Hour

COURSE NAME: CYBERSECURITY INCIDENT HANDLING AND RESPONSE
COURSE CODE: CSA6001

COURSE OUTCOME COVERED

CO1: Apply the concepts of cybersecurity incidents by distinguishing security events from incidents, implementing incident handling lifecycle stages, frameworks, with documentation practices in organizational contexts. (BL1, BL2)

Activity Tool : Incident Response Lifecycle Mapping (NIST/ISO 27035) (Medium)
Assessment Tool Weightage: 20%

Code of Conduct:

*I Abinesh M - 192465050 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student:

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Incident Response Lifecycle Mapping	30%	Correctly maps all lifecycle phases (Preparation, Detection & Analysis, Containment, Eradication, Recovery, Lessons Learned) in the proper sequence with no omissions.	Maps most lifecycle phases correctly with minor sequencing or content errors.	Includes only some lifecycle phases with noticeable omissions or incorrect sequencing.	Fails to identify or sequence the lifecycle phases correctly.
Application of NIST/ISO 27035 Framework	25%	Accurately applies the selected framework using appropriate terminology and activities throughout the response.	Applies the framework correctly with minor inaccuracies in terminology or activities.	Demonstrates partial understanding of the framework with several errors or omissions.	Incorrect or minimal application of the selected framework.
Reactive vs. Proactive Classification	20%	Correctly distinguishes all response activities as Reactive or Proactive with clear justification.	Correctly classifies most activities with minor errors or incomplete justification.	Partially correct classification with several misclassifications.	Incorrect or missing classification of Reactive and Proactive activities.
Flowchart Organization and Logical Representation	15%	Flowchart is well-organized, logically structured, easy to follow, and professionally presented using appropriate symbols.	Flowchart is organized with minor layout or sequencing issues.	Flowchart is partially organized but difficult to follow in some sections.	Flowchart is incomplete, poorly organized, or difficult to interpret.
Explanation and Technical Clarity	10%	Provides clear, concise, and technically accurate explanations supporting the incident response workflow.	Explanation is generally clear with minor technical or language errors.	Explanation is understandable but lacks clarity or technical accuracy.	Explanation is incomplete, unclear, or technically incorrect.

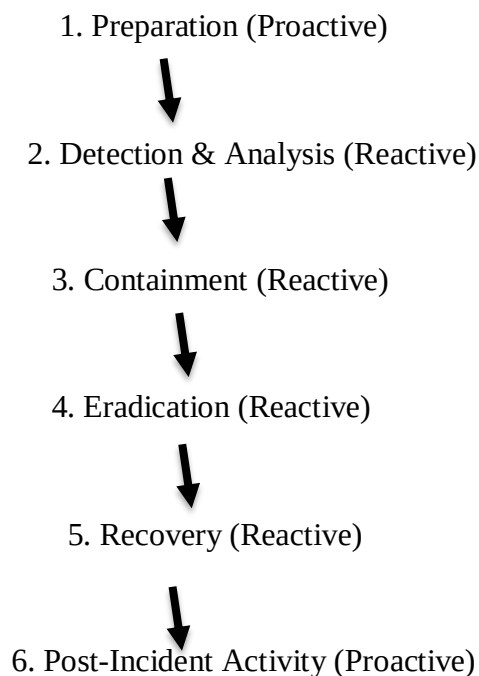
Criteria	Incident Response Lifecycle Mapping (4)	Application of NIST/ISO 27035 Framework (4)	Reactive vs. Proactive Classification (4)	Flowchart Organization and Logical Representation (4)	Explanation and Technical Clarity (4)	TOTAL (20)
Weightage	30%	25%	20%	15%	10%	100%
Q1						
Q2						
Q3						
Q4						
Q5						

Question 3: Insider Data Theft

Scenario

A database administrator (DBA) discovers that a senior employee accessed confidential customer records outside normal working hours and copied sensitive information to an unauthorized USB storage device. Audit logs confirm unusual file access and removable media usage. The organization starts an internal investigation and prevents further unauthorized access.

NIST Incident Response Lifecycle



Phase 1 – Preparation (Proactive)

Purpose

Preparation is performed **before any incident occurs**. The organization develops security controls, policies, and response plans to reduce the impact of future incidents.

Activities

- Create an Incident Response (IR) team.
- Develop an Incident Response Plan.
- Implement role-based access control (RBAC).
- Restrict USB device usage through security policies.
- Enable database audit logging.
- Configure Security Information and Event Management (SIEM).
- Train employees on data security.
- Classify confidential customer information.
- Prepare forensic investigation tools.
- Schedule regular security awareness training.

Why is it Proactive?

These activities are completed **before the insider theft happens** to reduce risk.

Phase 2 – Detection and Analysis (Reactive)

Purpose

Detect suspicious activity and determine whether an incident has occurred.

Activities

The Database Administrator notices:

- Customer records accessed outside office hours.
- Large number of confidential files opened.
- USB device connected.
- Audit logs show files copied to removable media.
- SIEM generates an alert.
- Security team reviews logs.
- Verify whether company policy was violated.
- Determine which data was copied.
- Identify the employee involved.
- Estimate the business impact.

Evidence Collected

- Database audit logs
- Windows Event Logs
- USB connection logs
- User login history
- File access timestamps
- CCTV footage (if available)

Why is it Reactive?

The organization reacts **after detecting suspicious behavior**.

Phase 3 – Containment (Reactive)

Purpose

Stop the incident from causing additional damage.

Activities

- Disable employee account immediately.
- Disconnect affected workstation.
- Disable USB ports.
- Block further database access.
- Preserve evidence.
- Create forensic disk image.
- Capture system memory.
- Notify management.
- Prevent deletion of logs.
- Monitor other privileged accounts.

Objective

Prevent additional confidential data from being stolen.

Why is it Reactive?

These actions are taken **after confirming the incident**.

Phase 4 – Eradication (Reactive)

Purpose

Remove the root cause of the incident.

Activities

- Remove unauthorized access permissions.
- Reset passwords.
- Revoke privileged accounts if necessary.
- Delete unauthorized software.
- Verify no malware exists.
- Patch security weaknesses.
- Review user privileges.
- Investigate whether additional employees were involved.

Objective

Ensure the insider can no longer misuse company resources.

Why is it Reactive?

These actions eliminate the cause of the incident after it occurs.

Phase 5 – Recovery (Reactive)

Purpose

Restore normal business operations safely.

Activities

- Restore secure database access.
- Re-enable legitimate user accounts.
- Restore files if altered.
- Monitor database activity.
- Verify that no additional confidential information is accessed.
- Confirm all systems operate normally.
- Continue monitoring for suspicious activity.

Objective

Return systems to normal while ensuring security.

Why is it Reactive?

Recovery occurs after the incident has been controlled.

Phase 6 – Post-Incident Activity (Proactive)

Purpose

Learn from the incident to prevent similar attacks.

Activities

- Conduct Lessons Learned meeting.
- Prepare final incident report.
- Update USB security policy.
- Improve access control policies.

- Increase monitoring of privileged users.
- Improve SIEM alert rules.
- Update Incident Response Plan.
- Conduct employee awareness training.
- Recommend Data Loss Prevention (DLP) solutions.
- Improve audit logging.

Deliverables

- Incident Report
- Root Cause Analysis
- Updated Security Policies
- Recommendations

Why is it Proactive?

The organization improves security to prevent future incidents.

Reactive vs Proactive Summary

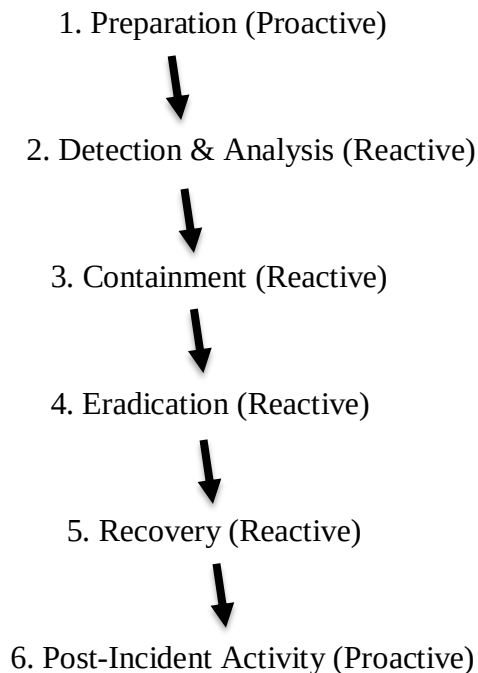
Phase	Action Type
Preparation	Proactive
Detection & Analysis	Reactive
Containment	Reactive
Eradication	Reactive
Recovery	Reactive
Post-Incident Activity	Proactive

Question 4: Malware Infection Through USB Device

Scenario

An employee connects a personal USB flash drive to an office computer without authorization. Antivirus detects malware attempting to modify critical system files and establish communication with a Command-and-Control (C2) server. The workstation is disconnected, and a forensic investigation begins.

NIST Incident Response Lifecycle



Phase 1 – Preparation (Proactive)

Activities

- Install enterprise antivirus software.
- Update malware signatures regularly.
- Disable unauthorized USB devices.
- Enable endpoint protection.
- Configure firewall rules.
- Create regular backups.
- Develop Incident Response Plan.
- Train employees not to use personal USB devices.
- Install Endpoint Detection and Response (EDR).
- Conduct security awareness programs.

Purpose

Reduce the possibility of malware infection.

Phase 2 – Detection and Analysis (Reactive)

Activities

Antivirus detects:

- Malware execution.
- Attempt to modify critical system files.
- Attempt to connect to Command-and-Control (C2) server.
- Alert generated by endpoint security software.
- Security team verifies infection.
- Identify malware type.

- Determine infection source (USB drive).
- Check whether malware spread to other systems.

Evidence Collected

- Antivirus logs
- Windows Event Logs
- USB connection logs
- Firewall logs
- Network traffic
- Memory dump

Purpose

Understand the malware and its impact.

Phase 3 – Containment (Reactive)

Activities

- Disconnect workstation from network.
- Block malicious IP addresses.
- Disable USB device.
- Isolate infected computer.
- Preserve forensic evidence.
- Prevent malware from spreading.
- Notify Incident Response Team.
- Stop suspicious processes.

Purpose

Limit malware damage.

Phase 4 – Eradication (Reactive)

Activities

- Remove malware.
- Delete malicious files.
- Scan the entire system.
- Remove persistence mechanisms.
- Patch operating system vulnerabilities.
- Update antivirus signatures.
- Verify malware is completely removed.

Purpose

Completely eliminate the infection.

Phase 5 – Recovery (Reactive)

Activities

- Restore clean files from backups if necessary.
- Reconnect workstation.
- Monitor for suspicious activity.
- Verify system integrity.
- Test applications.

- Ensure workstation functions normally.

Purpose

Safely return the system to production.

Phase 6 – Post-Incident Activity (Proactive)**Activities**

- Conduct forensic investigation.
- Prepare Incident Report.
- Identify root cause.
- Improve USB security policies.
- Block unauthorized removable devices.
- Update antivirus.
- Improve firewall rules.
- Conduct employee awareness training.
- Improve incident response procedures.
- Perform Lessons Learned meeting.

Deliverables

- Forensic Report
- Root Cause Analysis
- Updated Security Policies
- Lessons Learned Document